

PLATEFORME DE CYBERSÉCURITÉ UNIFIÉE

CyberRadar

Ingestion, détection, réponse et conformité dans une seule chaîne — et le chronomètre qui va avec.

32

services, une seule plateforme

9

étapes de l'événement au confinement

5

référentiels de conformité, dont la DNSSI

101/346

exigences livrées, et nous le disons

Quatre produits chez la plupart des éditeurs. Ici, une seule chaîne.

Collecter les journaux, détecter une attaque, ouvrir un cas, exécuter la réponse et en garder la trace sont quatre achats séparés, quatre intégrations et trois endroits où l'information se perd. CyberRadar les tient ensemble.

1 · INGESTION Le journal arrive collecteur, normalisation	2 · DÉTECTION La règle correspond moteur de corrélation	3 · QUALIFICATION L'analyste ouvre un cas SIEM → IR	4 · RÉPONSE Le playbook s'exécute SOAR	5 · CONFINEMENT L'adresse est bloquée politique réseau	6 · PREUVE L'audit nomme l'auteur journal immuable
--	--	---	--	--	--

Ces six passages sont exactement là où un produit assemblé perd l'information. La chaîne les mesure en neuf étapes — page suivante — à chaque modification du code, contre une plateforme réelle. La mesure est dans l'intégration continue, pas dans une plaquette.

Trois lecteurs, trois questions différentes

Direction générale

« Qu'est-ce que ça change, et qu'est-ce que ça engage ? »

Le problème, la chaîne, l'état réel du produit et ce que la suite demande.

Pages 4 à 7

Direction des systèmes d'information

« Est-ce que je peux l'exploiter, et le défendre devant un auditeur ? »

Architecture, sécurité, conformité marocaine, exploitation, et les limites mesurées.

Pages 8 à 12

Intégrateur

« Qu'est-ce que je déploie, qu'est-ce que je branche, qu'est-ce qui va me surprendre ? »

Déploiement, API, extension par le contenu, et ce qu'il faut prévoir.

Pages 13 à 16

Une convention tenue dans tout le document : chaque chiffre est mesuré sur le dépôt ou sur une installation réelle. Là où une mesure n'existe pas — la performance en charge, par exemple — il est écrit qu'elle n'existe pas, plutôt qu'estimée.

Le coût n'est pas dans les outils. Il est entre les outils.

4 à 6

éditeurs pour couvrir la même chaîne : SIEM, SOAR, gestion des vulnérabilités, conformité

3

endroits où l'information se perd : entre la détection et le cas, entre le cas et l'action, entre l'action et la preuve

0

chiffre commun : chaque outil mesure son propre délai, aucun ne mesure celui du client

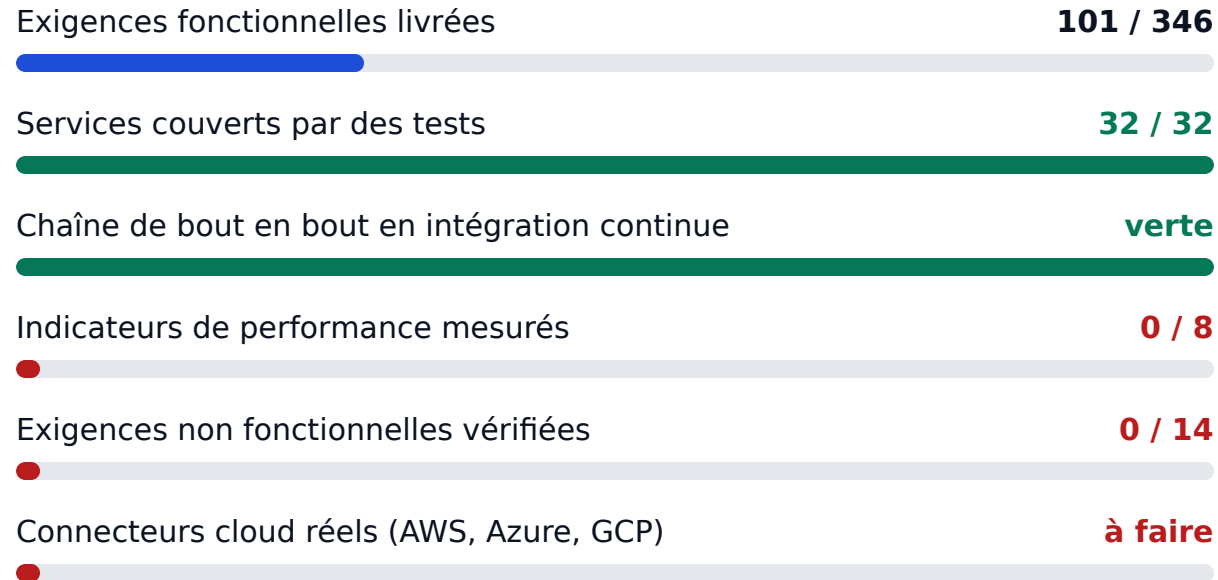
Un régulateur ne demande pas quels outils vous avez. Il demande combien de temps s'écoule entre l'intrusion et le confinement, et qui l'a décidé. Cette question n'a de réponse que si la chaîne est tenue d'un bout à l'autre.

De l'attaque au confinement, chronométré

Exécuté à chaque modification du code, contre une plateforme réelle. **La fourchette a une raison** : le cache de règles du moteur se rafraîchit toutes les 60 s, donc une règle écrite à l'instant s'applique quelque part dans ce cycle.

ÉTAPE	MESURÉ	BUDGET
Une règle de détection est écrite	6 ms	—
Un connecteur est raccordé	165 ms	—
L'attaque commence : six authentications en échec	41 ms	20 s
Le moteur lève l'alerte	2 s à 41 s	2 min 30
Un analyste promeut l'alerte en cas	8 ms	15 s
Un playbook de confinement est écrit	6 ms	—
Le playbook s'exécute jusqu'au bout	2 s	1 min
L'adresse est bloquée au niveau réseau	5 ms	1 min
Le journal d'audit nomme le playbook	14 ms	30 s
Total	4 s à 45 s	—

Où en est le produit, sans arrondi



Ce que cela veut dire

La plateforme est réelle et fonctionne. Elle couvre environ 30 % du périmètre qu'elle s'est fixé, et nous savons dire lequel, ligne par ligne.

Les chiffres de performance ne sont pas mesurés. Nous ne citerons donc pas de MTDD ni de MTTR : les mesurer est un chantier de dix jours, identifié et chiffré.

Un plan d'exécution découpe le reste en lots, chacun ayant une valeur autonome.

Une plateforme de sécurité qui annonce « tout est prêt » invite à vérifier. Nous préférons annoncer ce qui manque : c'est la seule façon de rendre crédible ce qui est là.

Ce que la suite demande

Ce qui est utilisable dès aujourd'hui

Une installation de démonstration ou de pilote, sur une machine, en une commande. L'interface, les 32 services, le jeu de données d'une banque de détail, la chaîne complète et le journal d'audit.

Ce que nous demandons à un intégrateur

De porter le déploiement et les connecteurs chez le client, avec notre documentation — 22 chapitres — et une API de 455 routes documentées.

Ce qu'un pilote chez un client demande

Les connecteurs vers ses sources réelles, la mesure de la performance sur son volume, et la revue de conformité avec son référentiel. Trois chantiers identifiés, pas des inconnues.

Ce que nous ne demandons pas

De croire un chiffre que nous n'avons pas mesuré. Tout ce qui est présenté ici est reproductible sur une machine, et nous le montrons.

La démonstration est le propos. En vingt minutes, une attaque traverse la plateforme de bout en bout devant vous, et chaque étape est chronométrée à l'écran.

Architecture

32

services en Go, chacun propriétaire de son schéma

5

magasins : PostgreSQL, ClickHouse, Kafka, Redis, Neo4j

455

routes HTTP servies, documentées

144

tables, 50 migrations à état

Le flux d'un événement

Collecteur → `crp.events.normalized` →
enrichissement (géolocalisation,
indicateurs, score) →
`crp.events.enriched` → moteur de
règles → `crp.events.alerts`.
ClickHouse garde l'historique,
PostgreSQL l'état.

Pourquoi Kafka au milieu

Un courtier coupé ne doit pas arrêter la
détection définitivement, et un service
redémarré ne doit pas perdre la fenêtre
pendant laquelle il était absent. Les
deux cas sont traités et testés.

Observabilité

OpenTelemetry sur les appels, métriques
Prometheus, traces Jaeger. Les
compteurs de seuil sont partagés dans
Redis : deux répliques atteignent le seuil
ensemble, pas chacune de son côté.

Sécurité de la plateforme elle-même

Une plateforme de sécurité est jugée d'abord sur la sienne. Voici ce qui est en place et vérifié par des tests.

- **Jetons signés RS256.** Clé privée chez le seul service qui émet, clé publique chez ceux qui vérifient. Aucun secret partagé entre services.
- **Autorisation à l'exécution.** Chaque route exige une permission nommée, résolue depuis les rôles de la personne — pas une vérification côté interface.
- **Cloisonnement multi-client.** Chaque écriture vérifie que l'objet visé appartient au client appelant, avant l'écriture et non après.
- **Journal d'audit sur les actions automatiques.** Un pare-feu modifié par un playbook laisse une trace nommant le playbook, l'acteur de service et la ressource.
- **Vulnérabilités des dépendances bloquantes.** `govulncheck` arrête la chaîne d'intégration ; les exceptions sont datées et expirent.
- **Secrets.** Client Vault en place. Les identifiants livrés avec le dépôt sont des identifiants de développement, et un script de durcissement les remplace.

Ce qui reste à faire, et qui est connu : l'audit de sécurité externe n'a pas eu lieu, et le chiffrement au repos dépend de la configuration de l'hébergeur plutôt que de la plateforme. Les deux sont dans le plan, pas dans un angle mort.

Conformité : les référentiels qui obligent ici

RÉFÉRENTIEL	PORTÉE	CONTRÔLES
DNSSI Directive Nationale de la Sécurité des Systèmes d'Information — DGSSI	Infrastructures d'importance vitale	6
Loi 09-08 Protection des données à caractère personnel — CNDP	Données personnelles, transferts hors du Royaume	5
PCI DSS 4.0 Industrie des cartes de paiement	Monétique, réseau GAB	10
SWIFT CSP Customer Security Controls Framework	Paielements internationaux	8
ISO/IEC 27001:2022 Management de la sécurité de l'information	Transverse	13

DORA n'y est pas

C'est un règlement européen : il n'oblige pas un établissement de droit marocain. Le citer ici décrédibiliserait le reste.

Le référentiel que vous apportez

Le code d'un référentiel était une liste fermée de sept valeurs européennes et américaines. Il ne l'est plus : la contrainte porte sur la forme. Un client arrive avec son cadre, il l'enregistre.

Ce qui se démontre

Les intitulés de contrôle sont **la correspondance de la plateforme**, pas une citation des textes : le mécanisme vaut pour n'importe quel référentiel.

Exploitation

Installation

Docker Compose sur une machine, ou un lanceur local pour un poste de développement. Infrastructure, schéma, contenu de détection, identités, services, interface : six étapes séparables, chacune reprenant là où elle s'est arrêtée.

6

travaux d'intégration continue : construction, analyse statique, tests, migrations, vulnérabilités, chaîne complète

Migrations à état

50 migrations derrière une table de version. Chaque fichier s'applique une fois, et une nouvelle migration s'applique à une installation **en service** — sans détruire la base. La chaîne d'intégration les applique deux fois de suite et exige que la seconde n'applique rien.

27 635

lignes de test pour 81 596 lignes de code

Contrôle avant-vol

Une commande donne un verdict avant toute démonstration ou mise en service : magasins, version du schéma, services interrogés deux fois, données, justificatifs, et l'attaque complète. Elle lit, elle ne répare pas.

36

unités déployables aujourd'hui ; la cible est 8 à 10, le regroupement est un chantier identifié

Les limites, mesurées

Ce que nous ne savons pas encore, et pourquoi c'est écrit ici plutôt que découvert en pilote.

- **Aucun indicateur de performance mesuré en charge.** MTTD, MTTR, débit d'ingestion : les mécanismes existent, la mesure sur volume réel n'a pas été faite. Chantier chiffré à dix jours.
- **Aucune exigence non fonctionnelle vérifiée.** Haute disponibilité, reprise après sinistre, tenue en charge : non éprouvées sur banc.
- **Pas de connecteur cloud réel.** AWS, Azure, GCP : la posture cloud se démontre sur données injectées par l'API, pas par découverte.
- **36 unités déployables.** Exploitable, mais lourd : un regroupement vers 8 à 10 unités est le prochain chantier d'exploitation.

Chacune de ces lignes correspond à un lot du plan d'exécution, avec sa charge estimée. Aucune n'est une surprise, et aucune n'est masquée.

Déploiement

- **Une machine suffit pour un pilote.** 8 cœurs, 32 Go. Docker et Compose, puis une commande.
- **Les identifiants sont paramétrés.** Un script génère les mots de passe, une nouvelle paire RSA, les origines et l'émetteur, et dit ce qu'il ne fait pas : HTTPS devant, et le pare-feu sur les ports qui n'ont aucune raison d'être joignables.
- **Le schéma se reprend.** Une installation antérieure à la table de version s'adopte par une commande, sans détruire la base.

Non vérifié à ce jour : le chemin Compose complet n'a pas été déroulé depuis que ses identifiants sont paramétrés. Déroulez-le une fois en entier avant toute mise en service, et considérez le chemin local comme la référence.

Ce qui va vous surprendre, et c'est écrit

PostgreSQL, ClickHouse et Neo4j ne lisent leur mot de passe qu'à la création de leur volume. Durcir une installation déjà démarrée ne change rien côté serveur, et l'erreur n'a aucun rapport apparent avec le fichier de configuration. Durcissez avant le premier démarrage.

Le démarrage échoue bruyamment

L'étape qui démarre les services renvoie un échec si l'un d'eux ne répond pas — elle se contentait d'un avertissement, et trois exécutions de la chaîne ont tourné sur une plateforme incomplète sans que personne le voie.

Intégration

455

routes HTTP, réponses normalisées

- **Tout passe par l'API.** Le jeu de démonstration lui-même est écrit à travers les routes publiques, sous une identité réelle avec de vraies permissions. Ce qui s'affiche a franchi la même validation qu'une saisie client.
- **Comptes de service.** Un automate obtient un jeton par échange d'identifiants, avec les permissions de son rôle et rien de plus.

22

chapitres de documentation, dont une référence d'API générée

18

écrans, internationalisés

- **Ingestion.** Un collecteur HTTP et un connecteur syslog. Les événements sont normalisés vers une taxonomie unique avant toute détection.
- **Erreurs utilisables.** Les erreurs de la base sont traduites en codes HTTP justes : un conflit est un 409, une validation un 422. Pas de 500 générique.

0

secret partagé entre services

Le contenu de détection se livre sans le code

C'est le point qui distingue une plateforme d'un projet : la couverture de détection est un objet versionné, signé, livrable à sa propre cadence.

CATALOGUE 15 détections publiées fichiers, pas migrations	PAQUET Construit et signé empreinte + signature	CANAL Publié, versionné rotation et révocation des clés	ADOPTION Le client prend ce qui lui convient 13 sur 15 dans la démonstration	GÉNÉALOGIE L'écart est traçable et défendable devant un auditeur
---	---	---	--	--

Pourquoi deux détections sur quinze ne sont pas adoptées

Parce qu'un client ne prend pas tout, et parce qu'un écran de couverture n'a d'intérêt que s'il a un écart à montrer. « Pourquoi celle-là n'est pas active » est la question qu'un auditeur pose, et elle doit avoir une réponse.

Ce qu'un intégrateur peut faire sans nous

Ajouter ses propres détections au catalogue, les signer avec sa clé, et les livrer à ses clients par le même mécanisme. Le format et l'outil de validation sont documentés.

Ce qu'il faut prévoir

SUJET	ÉTAT	CE QUE CELA DEMANDE
Déploiement d'un pilote	Prêt	Une machine, une journée avec la documentation
Connecteurs vers les sources du client	À développer	Collecteur HTTP et syslog en place ; chaque source propriétaire est un développement
Découverte cloud (AWS, Azure, GCP)	Absent	Lot identifié et chiffré ; aujourd'hui les données entrent par l'API
Mesure de performance sur le volume du client	Jamais faite	Banc à construire — dix jours, le premier chantier d'un pilote sérieux
Haute disponibilité	Non éprouvée	Les services sont sans état, les compteurs sont partagés ; la topologie reste à valider
Regroupement des 36 unités	À faire	Exploitable en l'état, lourd ; cible 8 à 10 unités

Un intégrateur qui lit ce tableau sait où il met les pieds. C'est l'intention : une surprise en pilote coûte plus cher que la même information donnée avant.

Vingt minutes, cinq temps

TEMPS	ÉCRAN	CE QUE VOUS VERREZ
2 min	Tableau de bord	Banque Al Massira — établissement fictif : 125 actifs, 24 agences de Tanger à Laâyoune, 412 constats de vulnérabilité, 72 alertes de la semaine Tout a été écrit à travers l'API de la plateforme, sous une identité réelle. Rien n'est injecté en base.
4 min	Détection et bibliothèque	14 règles actives, leur généalogie vers le catalogue signé, et l'écart assumé sur deux détections
5 min	L'attaque, en direct	Neuf étapes chronométrées à l'écran, de l'authentification en échec au blocage réseau et au journal d'audit
4 min	Conformité et risque	Les cinq référentiels, les écarts, et les seuils paramétrables sans livraison de code
5 min	La franchise	Les chiffres de la page 6 et de la page 12, dits à voix haute

Si la chaîne échoue devant vous, elle affichera la table de ses étapes et nommera lequel des passages a rompu, avec les offsets du courtier. Nous la lirons à voix haute : un outil qui dit précisément où il casse vaut mieux qu'un outil qui n'a jamais cassé devant personne.

Ce qui est vrai aujourd'hui

- **Une chaîne complète, mesurée.** De l'événement au confinement et à sa preuve, exécutée à chaque modification du code.
- **Un socle tenu.** 32 services, aucun sans test, 50 migrations à état, six travaux d'intégration continue.
- **La conformité du Royaume.** DNSSI, loi 09-08, PCI DSS, SWIFT CSP, ISO 27001 — et le référentiel que le client apporte.
- **Pas de chiffre de performance.** Nous ne vous en citerons aucun avant de l'avoir mesuré chez vous.
- **Pas de connecteur cloud réel.** Lot identifié, chiffré, pas commencé.
- **Environ 30 % du périmètre visé.** 101 exigences sur 346, et nous savons dire lesquelles.

La prochaine étape que nous proposons : un pilote sur un périmètre restreint, chez un client, avec la mesure de performance comme premier livrable. C'est le seul chiffre qui manque pour que tout le reste soit défendable.